

Trove Inc.

IR Plan

Contents

Purpose.....	1
Authority	4
Scope and Roles	4
Communication.....	8
Procedure.....	8
Dissemination	8
Training	12
Testing	14

Glossary

IR	Incident Response
IRT	Incident Response <u>What is Bandcamp?</u> At its core, Bandcamp is a music hub. It contains an online record store and a vibrant music community. Fans can connect with their favorite artists, labels, and like-minded users. This hub encourages discovery and provides avenues for finding soundscapes, both familiar and unknown. All those features are accomplished through ethical practices, and musicians can find genuine support for their craft, which is rare today. <u>The Store</u> Bandcamp’s online record store enables artists and labels to earn revenue for their work. Any

	musical expression can be sold in physical formats, like records, or digital formats, like MP3s. Additionally, musician and record label-branded clothing can be sold. Collectors of physical products, like records, CDs, and cassettes, have an extensive selection to choose from. Digital media enthusiasts, individuals with a Bandcamp Collection or music player, have just as broad a catalogue. Nonetheless, the unique aspect of the store, and a massive part of the hub's ethical practices, is its distribution of profits. 82% of the total earnings a product accumulates goes directly back to those who. The remaining percentage is retained by Bandcamp. These figures are significantly better than anything a streaming service like Spotify could provide. <u>Clubs</u> For most listeners, venturing into unknown territories is a priority, one that the hub excels in fulfilling. Clubs is a monthly subscription priced at 13\$. Despite its cost, it does an exceptional job at creating groups of songs and albums based on a theme, genre, or sound. Featured songs or albums get added directly to the subscriber's collection, making the service like a streaming platform. Even so, unlike most streaming platforms, AI does not curate these collections; instead, journalists, collectors, and other enthusiastic eccentrics do the compiling. <u>Daily</u> Daily, an editorial, is yet another system that provides an opportunity to explore new sounds. Daily provides writing publications on music projects that match categories such as genre, vibe, or history. Each issue dives into artistry, both past and present. Within some entries, along with featured projects, education on the historical and cultural impacts can be found. Moreover, it serves as a contribution to the vitality of music journalism, an underrated form of media. Collection Team
CIO	Chief of Information Systems

IA	Information Analyst
----	---------------------

Purpose and Goals

Purpose

Trove Incorporated always strives to help music lovers of all kinds discover new music. It brings together the music community and connects with others. Users will always come away with new recommendations that are accurate and personal.

Algorithms and discoveries that are humanistic are essential in the world of Artificial Intelligence. The security of users' precious information, the data that makes up their trust in our service, is of the utmost importance.

Goals

Trove Inc. strives to provide a seamless experience for its users, ensuring trust that is built on the security and responsible use of their data. Trove must provide a service that feeds users' love for music without failure or disruption.

Authority

The lead in the cybersecurity sector, the CIO, is the role responsible for decisions in IR, and dictating when it should be executed. Thus, the CIO is the authority figure.

The authority figure is responsible for:

- Deploying the IR Team.
- Making major decision making in IR.
- Applying containment procedures.
- Coordination between departments.
- Supporting employees with assistance.

All employees who fail to comply with the IR order may face disciplinary action.

Scope and Roles

Scope

This IR Plan covers all cybersecurity incidents that could affect Trove's information systems.

For instance, threats that impact cloud services, employment logistics, sensitive user/company data, production logistics, or system information.

It applies to all employees, contractors, business partners, private partners, third-party managers, and any cloud resources owned and operated by Trove.

The plan also covers threat level incidents.

Threat levels are dictated as follows:

Critical severity	Active attackers causing critical damage to information integrity and stability (Users' banking and login credentials) Greater than \$100,000 in damage.
High Severity	Systems holding confidential or sensitive information (both streaming and organization credentials and banking) are being attacked. – Remote control attacks. \$50,000 – \$100,000 in damage.
Medium Severity	Attacks that extract company information and install malware on one device. \$25,000 – \$50,000 in damage.

Low Severity	Compromise that does not involve sensitive information. There is no lateral compromise of organizational assets. Less than \$25,000 in damage.
Informational	Unsuccessful attacks like phishing, probes, and scans. Events are factored into threat assessment, and monitoring is put in place. No cost in damage.

Roles

Roles and responsibilities are distributed by the CIO.

Each role involved in the IRT is described as follows:

CIO: The definitive authority figure of the IR. The CIO must handle internal communication, external communication, and role distribution.

Information Analysts: Following the IR procedure steps, the IA performs containment, identification, and eradication.

IRT Manager: The IRT manager oversees the IR execution. This role must make prudent and calculated decisions. All decisions must support the IRT team, and the protection or containment of company data. Anything that happens within the IR must be reported to the CIO.

Legal Council: to date with all information security regulations, both legal and industry, the Legal Compliance Manager must consult with other roles in decision-making.

IT Manager: The IT manager provides support in all infrastructure security tasks. Closely collaborating with IAs, this role must assist in things like re-imaging/resetting devices, containing threats, backups, etc.

Communications Manager: The Communications Manager oversees all external and internal stakeholder notification. This role works in accordance with the CIO.

Human Resources (HR) Manager: The HR Manager is involved in any implications a threat has on employees or relations.

Communication

Goals for the communication plan are as follows:

- Ensure trust.
 - Show group effort and collaboration.
 - Be transparent with Stakeholders.
 - Seeking support and assistance from partners.
 - Be transparent with all users.

Communication is split into role specifics.

Communications Manager: The Communications Manager oversees all notifications to external stakeholders, internal stakeholders, and business partners.

CIO: The CIO oversees all notifications to any technology contractors, partners, or third-parties.

HR Manager: The HR Manager oversees all notifications to internal employees.

Procedure

The procedure is based on the PICERL system.

P

- Preparation
 - Plan
 - Plan for all threat severities. Methods for tackling a cybersecurity threat must be established.
 - Organize and equip

- Organize and equip all employees. All employees must be able to carry out their roles.
- Train
 - Training employees is crucial. They must receive adequate education of Trove's purpose/goals and how to effectively mitigate threats that hinder our mission.
- Exercise
 - For training to be effective, it must be practiced. Following the tabletop scenario is the best way of instilling the principles of training completely in employees.
- Evaluate and improve
 - View the exercise(s) as a benchmark. Recognize what went well, and what did not. Use the benchmark to improve upon any weaknesses employees and/or sectors have.

I

- Identification

- Detect and verify a threat
 - Dictate whether the threat is a false alarm or not.
 - If the threat is real, what is its severity?
 - Precursors and indicators
 - Identify what led to the discovery of the threat.
 - Learn what led to the threat's occurrence.
 - Correlating information
 - Identify commonalities and patterns. Dictate reoccurring threats and/or vulnerabilities.
 - Research
 - Discover characteristics about a threat and learn about any characteristics not already known.
 - If an incident has occurred.
 - Begin documentation and make all factors above clear.
- Prioritize the incident based on varying factors (functional impact, information vulnerability, recoverability capability).
- Report incidents to appropriate personnel.

C

- Contain
 - Acquire, maintain, secure, and document evidence
 - Use the identification process.
 - Explain how the threat was identified, what led to it, and the vulnerability it exploited
 - Properly store and maintain this evidence for documentation.
 - Contain the incident
 - Separate infected devices from important networks or infrastructures.
 - Minimize the damage the threat causes.

E

- Eradicate
 - Identify and mitigate vulnerabilities exploited.
 - After the vulnerability that was exploited is discovered, learn how to mitigate it.
 - Explain new safeguards put into place, and why they were implemented.
 - Remove all malicious software, materials, hardware, or other related parts.
 - Use methods such as reimaging to remove malicious software from devices.
 - If hardware is unable to return to an operable state, replace it.
 - Repeat Detection/Verification and Analysis steps if other devices are compromised.
 - For all infected devices, repeat steps above to ensure the threat is gone.

R

- Recover

- Return formerly compromised devices/systems to operable state.
 - If any back ups are stored, utilize them.
 - If back ups are not applicable, attempt to return devices to an operable state.
 - If that is not possible, replace the device.
- Confirm devices/systems are operating functionally.
 - Make sure infected devices that were restored are working properly across the board.
- Implement additional monitoring protocols/methods.
 - Mitigate any current vulnerabilities, and new ones that may arise.

L

- Lessons or Lessons Learned

- Document all findings.
 - Follow-up reports.
 - Causation.
 - Explain what caused the threat.
 - Evidence.
 - Explain any indicators to the threat that was present.
 - Vulnerabilities.
 - Explain what vulnerability was exploited by the threat.
 - Logs.
 - Explain any logs or audits that possess metrics and if they could prove to be useful when analyzing the threat.
 - Etc.
- Conduct a briefing on all documented findings and explain what to do next.

Dissemination

This document, the IR Tabletop, and any related logs/metrics should only be distributed to those it is relevant to and those authorized to view it.

Default viewing authority:

CIO	The CIO is the definitive authority figure in IR. They have full access to the IR Plan.
IRT Manager	The IRT Manager has readability. They must understand the IR to oversee the IR Team.
Approved contractors, partners, federal authorities, and outside agents.	External resources have access, upon approval, to readability.

Reports, logs, and metrics access is to be given to:

- Cyber and IT leads
- Analysts
- Engineers

Distribution of the above documents to non-authorized individuals may result in disciplinary action.

Training

Trove, without fail, must maintain a consistent and up-to-date training system. Training will apply to all employees, regardless of sector. These principles will ensure every employee understands their role and requirements within IR.

Training will include:

- A role specific training program.
 - This program will specialize in individual fields.
 - It must be tailored to individual roles.
 - This is crucial to making sure everyone knows their responsibilities perfectly.
- A general training program.
 - This will ensure that all personnel will understand our purpose, and why IR is important to stay true to our purpose.
- An advanced training program.
 - This program is for higher ups.
 - The program must be tailored to more advanced concepts.
 - It must cover concepts of company characteristics.
 - It must cover concepts of industry characteristics.

Testing

Testing is a key principle in ensuring the preparedness of all personnel in the case of a real-time incident. For that to happen, the IR Plan must be tested and updated regularly.

Testing goals are as follows:

- Gain insight
 - All sectors must collaboratively provide insight.
 - Involve approved and relevant external partners/contractors and stakeholders.
 - MSSPs
 - Cybersecurity Insurance Reps
 - Any other partners deemed relevant by CIO
 - Improvements to user experience, algorithms (recommendations of music), and cybersecurity is imperative.

The testing process is as follows:

- Refer to the company's IR Tabletop.
- The IR Tabletop will be changed/updated to evaluate lessons learned about the current most severe threat.
 - Poses a high damage cost.
- Tests will be in quantifiable metrics and digestible documentation.
- The test will improve lessons learned and contingency plans.
- The testing process will also serve as a training resource.

The testing mediums are as follows:

- An IR Tabletop
 - Various scenarios are discussed among the whole of the IRT.
 - The managers will then discuss the team's findings.
 - Collaborative input will be taken into consideration by all sectors involved.
- A simulation test
 - The simulation test will allow staff to effectively put the IR Procedure into practice.
 - These tests will be conducted on a yearly basis.
 - Updates and further training will be put into place based on results.

Sources

CSF Tools. (n.d.) *NIST SP-800-53 IR-8*. IR: Incident Response. [Link](#).

CSF Tools. (n.d.) *NIST SP-800-53 IR-4 (8)*. IR: Incident Handling. [Link](#).

CSF Tools. (n.d.) *NIST SP-800-53 IR-2*. IR: Incident Response. [Link](#).

CSF Tools. (n.d.) *NIST SP-800-53 IR-2 (3)*. IR: Incident Response Training. [Link](#).

CSF Tools. (n.d.) *NIST SP-800-53 AT-2*. AT: Awareness Training. [Link](#).

CSF Tools. (n.d.) *NIST SP-800-53 AT-4*. AT: Awareness Training. [Link](#).

CSF Tools. (n.d.) *NIST SP-800-53 CP-3*. CP: Contingency Planning. [Link](#).

CSF Tools. (n.d.) *NIST SP-800-53 SA-5*. SA: System and Services Acquisition. [Link](#).